

FASTAPI ENTERPRISE SECURITY AUDIT REPORT

Target Application: enterprise-ai-business-automation

Live URL: enterprise-ai-business-automation-p.vercel.app

Lead Security Consultant: (Priyanshu Full-Stack AI Engineer & Security Consultant)

Audit Date: September 28, 2026

Status: ACTION REQUIRED (Vulnerabilities Detected)

1. EXECUTIVE SUMMARY

A targeted production-level security audit was conducted on the core API endpoints and infrastructure of the 'enterprise-ai-business-automation' application hosted on Vercel. While the application leverages Vercel's edge network layer for SSL, multiple severe vulnerabilities regarding missing server-side security headers, weak input schema definitions, and verbose error handlings were identified. Immediate remediation is strongly advised to prevent data scraping, clickjacking, and API authentication bypasses.

2. AUDIT CHECKLIST & REAL FINDINGS

VULNERABILITY 1: Weak Password Policy & Input Schema Bypasses

- **Severity:** High
- **Observation:** The API route for registration/authentication accepted single-character strings ("a") without enforcing complex regex patterns or length boundaries.
- **Impact:** Leaves the application highly vulnerable to automated credential stuffing, brute-force attacks, and account takeover.
- **Remediation:** Update the Pydantic input models to enforce constraints: `Field(..., min_length=8, regex="^[a-zA-Z0-9...]" )` .

VULNERABILITY 2: Missing Security Hardening Headers (Vercel Edge Level)

- **Severity:** Medium
- **Observation:** A DevTools (F12) Network scan revealed that the FastAPI backend response headers are completely missing:
 - X-Frame-Options
 - Content-Security-Policy (CSP)
 - X-Content-Type-Options: nosniff
- **Impact:** Exposes users to Clickjacking and cross-site scripting (XSS) script injections mimicking the application frontend.
- **Remediation:** Inject FastAPI's custom middleware or add a `vercel.json` headers configuration file to enforce security values at the routing level.

VULNERABILITY 3: Verbose Error Messages & Stack Trace Leakage

- **Severity:** Medium
 - **Observation:** Sending invalid JSON payloads or hitting non-existent endpoints triggers explicit Uvicorn/FastAPI internal validation tracebacks instead of generic masked error responses.
 - **Impact:** Information leakage gives malicious users direct reconnaissance details about your internal folder structure and database architecture.
 - **Remediation:** Implement a global `@app.exception_handler(RequestValidationError)` to return generic standardized server messages.
-

3. REMEDIATION TIMELINE & EFFORT PLAN

- **Phase 1 (Immediate Patches):** Fix missing HTTP headers and input sanitization (Effort: 2 hours).
- **Phase 2 (Auth Security):** Secure route access tokens and set up basic rate limiting limits (Effort: 4 hours).